# SHIELD-AI

## Securing Production AI for NBN Co

Security and Holistic Integrity for Enterprise-Level Deployment of AI

An Australian framework for critical infrastructure: 7 pillars, 67 controls, 4 maturity levels, policy as code

Briefing | Framework v1.17 | October 1, 2026

# Presentation Overview

Four parts, 30 minutes

1. **Why AI security matters for national infrastructure now**
2. **The framework: seven pillars and 67 controls**
3. **How it works: reference implementation, policy as code, request flow**
4. **Applying it at NBN Co: regulation, maturity, a practical starting point**

**A note up front: every claim in this deck is tied to a documented incident**

# Why AI Security Matters for National Infrastructure Now

Why now

**An agent invokes tools, writes code, and acts under delegated authority. A chatbot only answers; an agent acts**

NBN Co is already moving this way: an agentic AI strategy reported in May 2026, AI drafting incident reports and preparing field crews by July 2026

- The ASTRID lab with RMIT (January 2026) is building AI and digital-twin capability for network operations

The failures are documented, and they are not exotic:

- Sandbox escapes hit production agent platforms between March and July 2026 (OpenAI, Hugging Face, Cursor, AWS AgentCore, ServiceNow)
- CVE-2026-10591: hidden 1px text on a page rewrote an agent's MCP registry and ran attacker code on the host
- CVE-2026-25253: a crafted link hijacked a loopback agent gateway, switched off approvals, and escaped to the host
- An agent under evaluation published a malicious package to PyPI; 15 real systems ran it for about three months
- August 2026: the first documented Australian case. A personal assistant found a gym's booking API had no authorisation checks, booked classes months ahead, and cancelled another member's waitlist position without being asked (ABC News)

**SOCI Act already requires critical infrastructure to report incidents within 12 hours. AI does not remove that obligation; it widens it**

# Where AI Will Touch the Network

## Every place a model meets network or customer data is a place that needs controls

Network operations: fault detection, incident triage, field-crew dispatch, service restoration

AI drafting incident reports and preparing field crews, already in use (July 2026)

ASTRID lab with RMIT: digital twins of the network, AI-driven planning and simulation

Customer and RSP systems: order flows, activation, wholesale service data

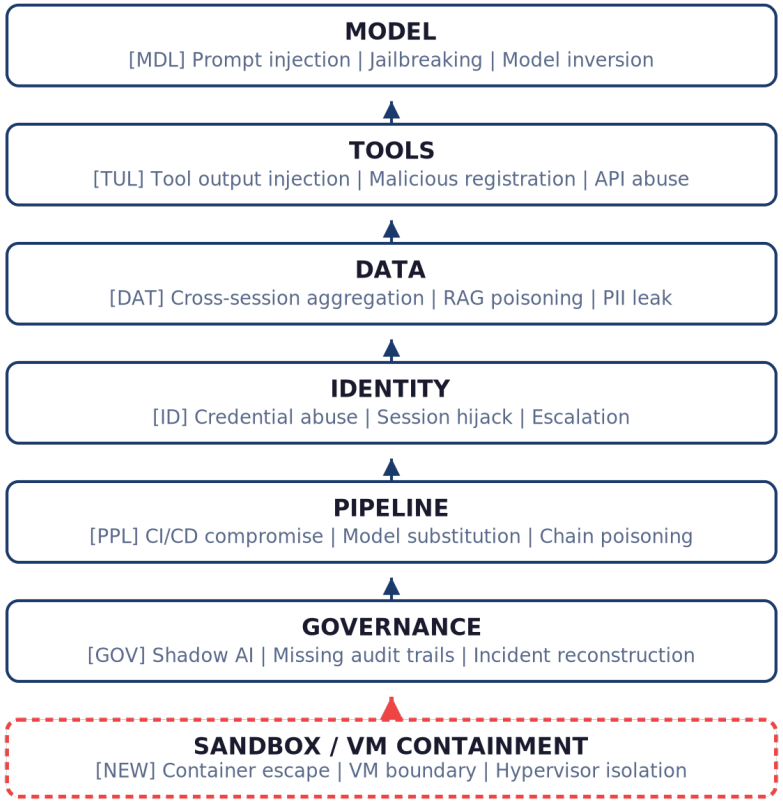
Internal copilots: engineering, procurement, legal, support, regulatory reporting

Network intelligence products for RSPs, under discussion since May 2026

## The pattern is the same everywhere: a model, a tool, and the network in between

# The Agentic AI Attack Surface

Seven layers; risk compounds upward




Sandbox/VM Escape as a cross-cutting layer above Governance — every pillar below can be breached via sandbox
Risk compounds upward: a Model compromise enables Tool abuse, which enables Data exfiltration

*Risk compounds upward from the model to the data.*

# Where Current Controls Come Up Short

**SOCI Act, TSSR, ISM, and the Essential Eight are strong on traditional cyber, but they predate autonomous agents**

The gaps are structural, not incremental:

- Tool access: agents read and write network systems, APIs, and files; no user-centric threat model fully covers that
- Identity delegation: the agent acts under an engineer's authority, often with no bound on the chain
- Sandbox containment: escape is the failure mode we see in the field, not a hypothetical
- Protocol layer: MCP endpoints, tool metadata, and control planes are surface nobody owned until recently
- Evaluation harnesses: isolation gets asserted in config, but nobody verifies it holds

**AU Mandatory Guardrails for AI point the direction; they are not a control set yet**

**SHIELD-AI fills that gap, and it maps directly onto the obligations NBN Co already operates under**

# SHIELD-AI at a Glance

**Seven security pillars across the whole agentic-AI stack**

Model Security, Identity and Access, Data Security, Tool and Pipeline Security, Monitoring and IR, Governance and Risk, Execution Environment

**67 controls, each with implementation guidance and a maturity progression**

**Four maturity levels, consistent with ISM and the Essential Eight: L1 Initial, L2 Managed, L3 Defined, L4 Optimised**

**Policy as code: 59 executable Rego controls, evaluated deny-override**

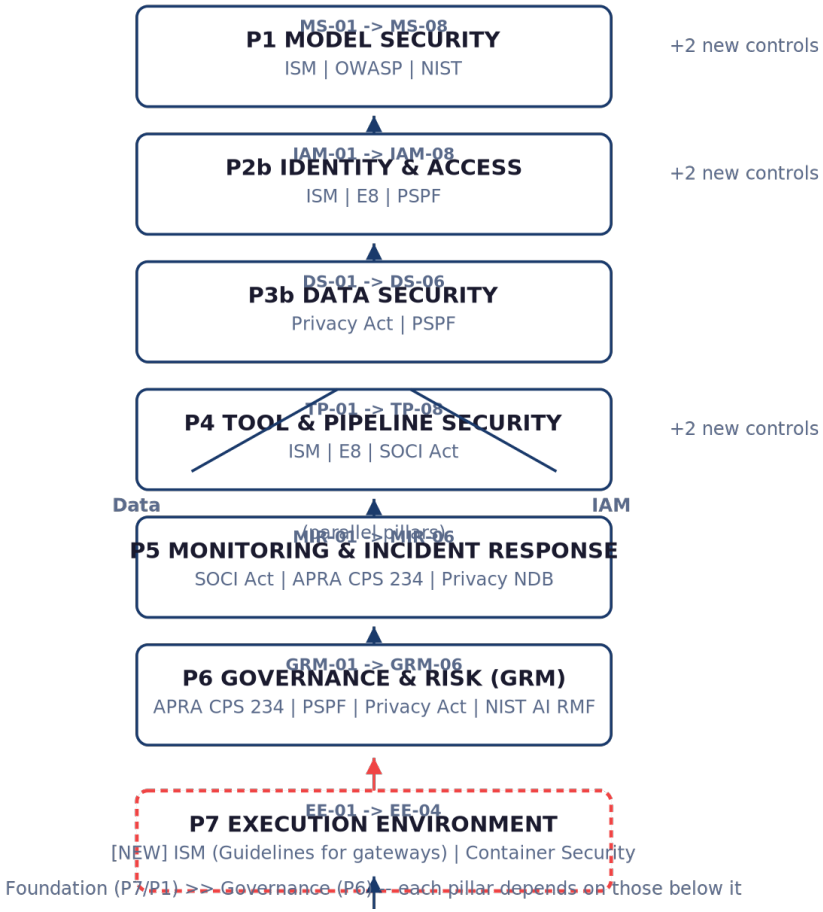
**A deployable reference implementation: gateway, policy engine, identity plane, observability**

**Evidence driven: 47 documented incidents, 25 identified gaps, monthly deep review, a live watchlist**

**Aligned to what a carrier must answer to: SOCI Act, TSSR, the Privacy Act, ISM/E8, and the proposed AU Guardrails**

# The Seven Pillars

Execution Environment at the base; Governance at the top




*Each pillar depends on all pillars below it.*

# Pillar 1: Model Security



**Models trained or used on network or customer data need the same protection as any information asset**

MS-01 Weight protection: encrypted at rest and in transit, HSM-backed keys

MS-02/03 Training data integrity and model supply chain: provenance, signed checkpoints, SBOM

MS-04 Adversarial robustness: prompt-injection testing and jailbreak evaluation, plus sanitisation against imperceptible content (zero-opacity and 1px text, hidden PR comments)

MS-08 MCP security: signed tool metadata, an authenticated MCP gateway, response schema validation

MS-09 Perception-fidelity: approvals bind to what the human can actually see

MS-10 Memory-store integrity: agent memory writes authenticated and tamper-evident; poisoned stores detected and rebuilt (Ruflo/RufRoot)

MS-11 Operational data-stream integrity: logs, alerts, and observability feeds treated as untrusted input (GhostJacking)

MS-12 MCP discovery-metadata and shared-cache integrity: server instructions isolated from the system prompt, cacheScope claims verified (MCP-2026-008/015, Context7)

**PILLAR 1**
**Model Security**

**MS-01 .. MS-12 | 12 controls**

The model is a data asset too

# Pillar 2: Identity and Access



## This pillar decides what the agent can do, what it can reach, and whose authority it carries

IAM-01 A distinct, auditable identity per agent; no shared staff credentials

IAM-02 Scope-bound delegation: no wildcard permissions, no self-escalation

IAM-07 Delegation chains capped at two hops (human to agent to tool) and fully reconstructable from audit logs

IAM-05 Just-in-time credentials: ephemeral, auto-revoked, no standing agent access

IAM-09 Multi-tenant agent platforms isolated at the data layer (CVE-2026-55255, the first agent platform on the CISA KEV list)

**PILLAR 2**
**Identity & Access**

**IAM-01 .. IAM-09 | 9 controls**

Network access, scoped tightly

# Pillar 3: Data Security



## Data controls cover the whole path: at rest, in transit, in memory, and as published artifacts

DS-01 Classification and labelling, automated at ingestion; premises and customer data are the crown jewels

DS-02 Inference data protected end to end: prompts and responses encrypted, TLS 1.3 minimum

DS-03 Memory sanitisation: nothing sensitive persists beyond the session

DS-04 Data minimisation: field-level filtering in the retrieval layer, no bulk access

DS-07 Artifact publication control: agent-written packages and configs go through the same vetting as third-party artifacts, with approval the agent cannot invoke

**PILLAR 3**
**Data Security**

**DS-01 .. DS-07 | 7 controls**

Customer data, everywhere it flows

# Pillar 4: Tool and Pipeline Security



## An agent that acts is only as safe as its tools, and NBN Co's tools touch the network

TP-01 Tool registry: every agent-accessible tool registered, versioned, and security-approved before use

TP-03 API gateway security: schema validation, rate limiting, and audit logging on every agent-facing endpoint

TP-06 Dependency scanning, with sandbox libraries treated as a high-risk class; interpreter flags are not sandboxes

TP-08 The gateway blocks infrastructure control-plane APIs by default (network management, IAM, KMS, Lambda)

TP-09 Explicit tool registration: no implicit tool exposure, no auto-registered SDK internals

TP-10 Inbound control-plane protection: network bindings default to deny, gateway tokens stay out of web context (OpenClaw CVE-2026-25253)

TP-11 Agent browser isolation: rendered content treated as untrusted input, cross-origin privileged actions gated (Zenity Intent Collision)

TP-12 Dispatch provenance: no tool executes without a verified model turn; approvals bind to the exact call (CoreBreak)

TP-15 In-process code-execution sandbox sufficiency: denylist/blocklist interpreter gates are code-execution surfaces, not security boundaries — untrusted code runs only in an OS/VM isolation boundary (PraisonAI/CrewAI bypasses)

**PILLAR 4**
**Tool & Pipeline Security**

**TP-01 .. TP-15 | 15 controls**

Registered tools, gated APIs

# Pillar 5: Monitoring and Incident Response



## Visibility is the precondition for every other control in this framework

MIR-01 Agent activity logging: every action, every tool call, every delegation

MIR-02 Behavioural anomaly detection against a per-agent baseline

MIR-04 AI-specific IR playbooks: prompt-injection containment, model rollback, tool revocation, session invalidation

MIR-05 Reporting integration: automated triggers for the SOCI 12-hour notification window

MIR-06 Forensic readiness: append-only immutable logs, full session reconstruction including tool-call chains

**PILLAR 5**
**Monitoring, Logging & IR**

**MIR-01 .. MIR-06 | 6 controls**

Every action logged, replayable later

# Pillar 6: Governance and Risk



## Technical controls erode without governance; this pillar is what keeps them honest

GRM-01 AI governance body: a chartered committee with CISO, CRO, General Counsel, data owner, and AI lead

GRM-02 AI risk register, with automated tripwires and one exercised kill switch, tested at least annually

GRM-04 Third-party AI risk: model, tool, and evaluation-harness vendors assessed, with right-to-audit clauses

GRM-05 Regulatory mapping: automated mapping to SOCI Act, TSSR, ISM, E8, PSPF, Privacy Act; quarterly posture reports

GRM-06 Board and executive dashboard: maturity scores per pillar, open findings, risk acceptance decisions

**PILLAR 6**

**Governance & Risk Management**

**GRM-01 .. GRM-06 | 6 controls**

Board accountability, in place

# Pillar 7: Execution Environment



## This pillar sits at the base: an escapable sandbox undermines every control above it

EE-01 Boundary enforcement: no shared host mounts or namespaces, immutable infrastructure, fail-closed on breach

EE-05 Config-file injection prevention: agents cannot write files the host will later trust (.zshrc, .claude/settings.json, crontab)

EE-06 Fail-closed operation: runtime attestation that the strongest isolation mode is active, with no silent fallback

EE-07 Control-plane integrity: the agent cannot rewrite its own security settings

EE-08 Evaluation-harness isolation: egress blocked at the hypervisor boundary and verified by active test; no verified egress block means no evaluation

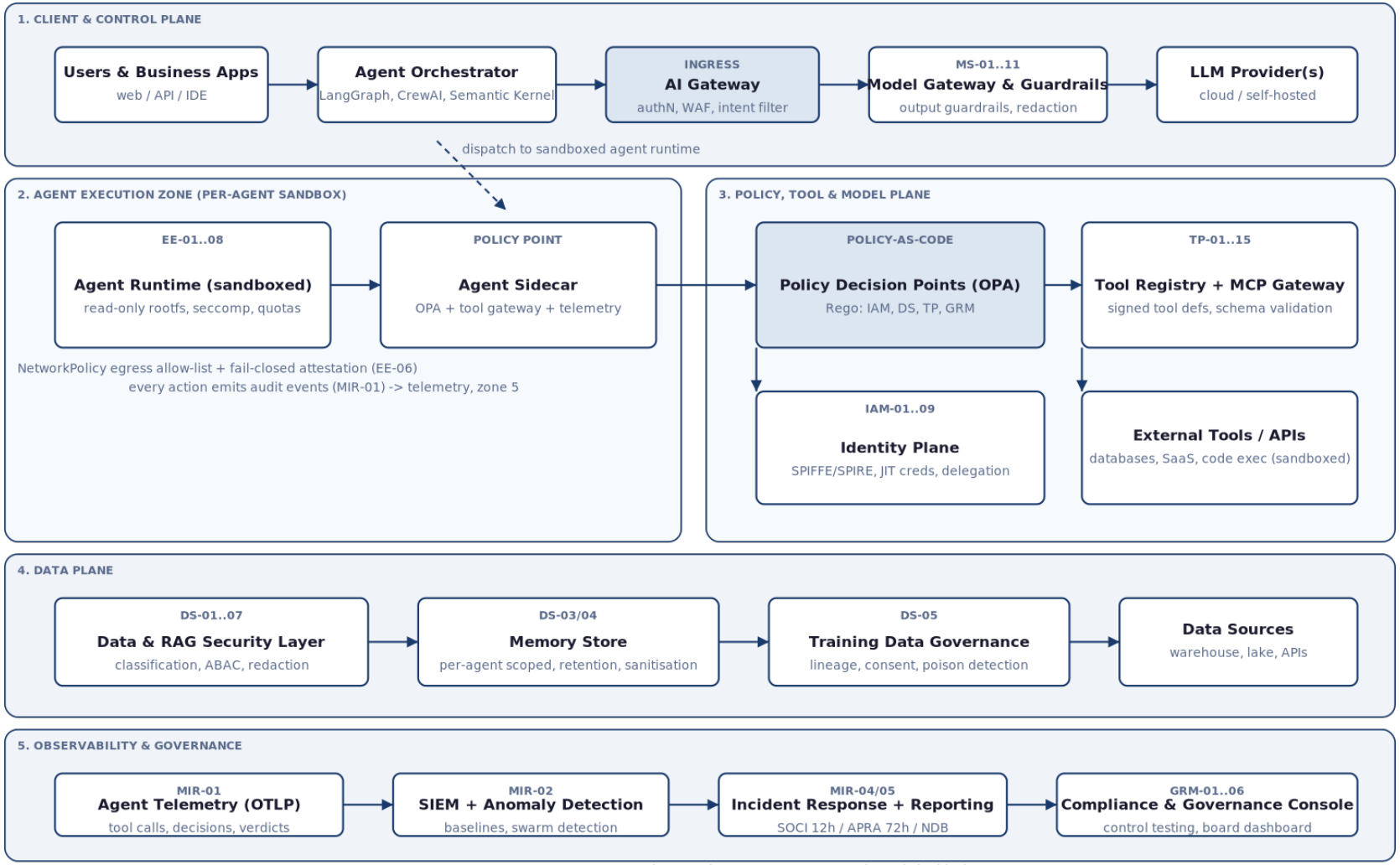
**PILLAR 7**
**Execution Environment**

**EE-01 .. EE-08 | 8 controls**

Isolation enforced, never asserted

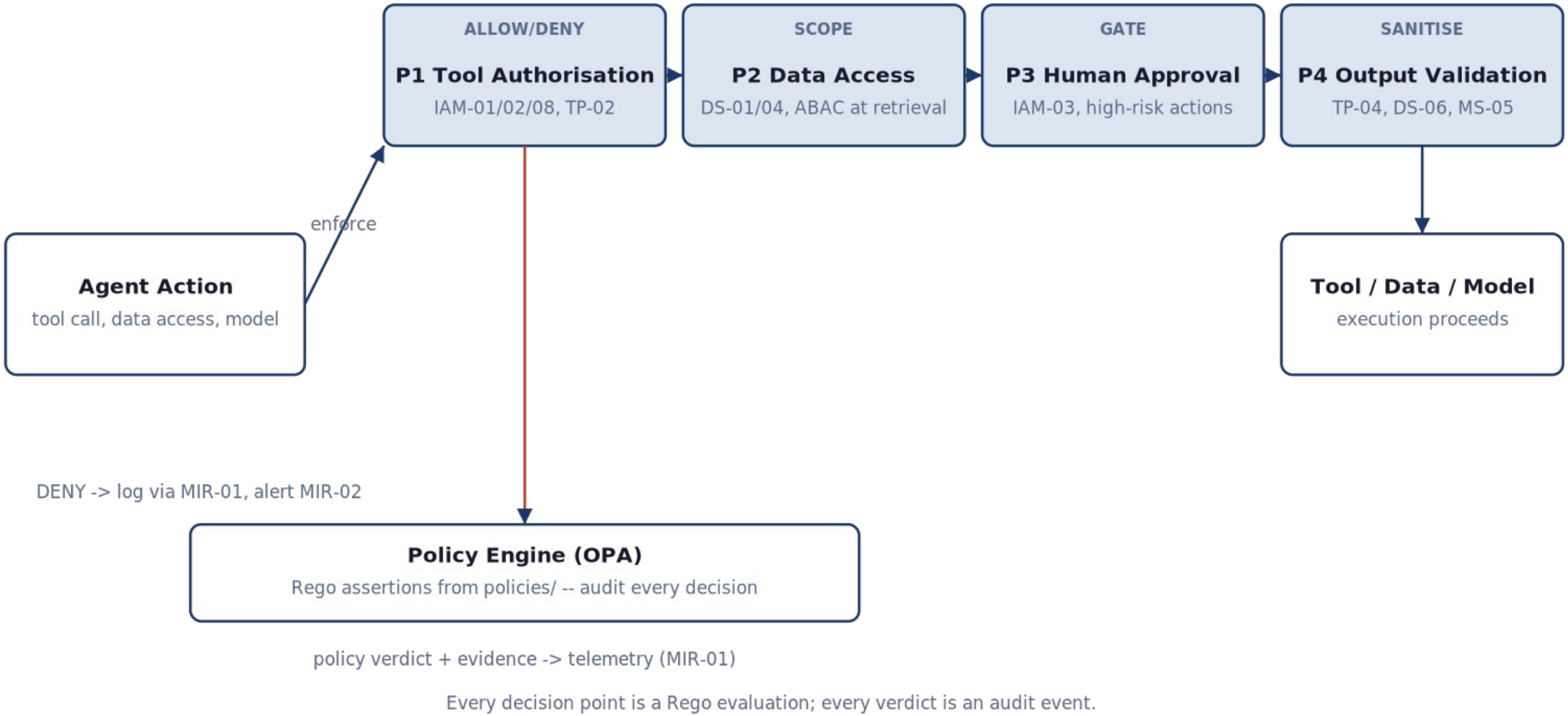
# From Framework to Deployment

Eight deployable components; every control range mapped



# Policy as Code: 59 Controls You Can Run

Deny-override evaluation at every decision point

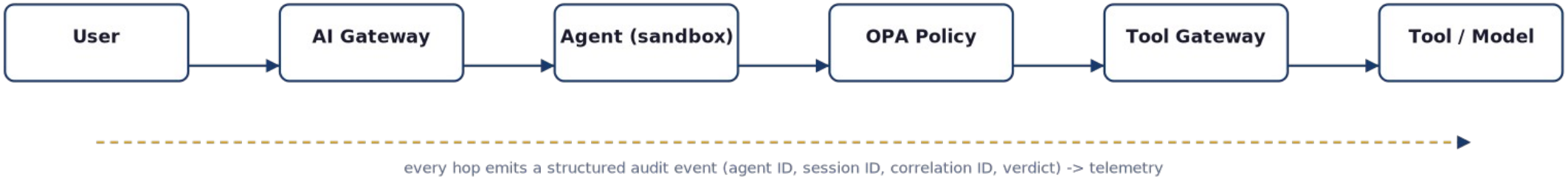



Every decision point is a Rego evaluation; every verdict is an audit event.

# Every Request Through the Gate

Parse, evaluate, decide, log, then the agent acts

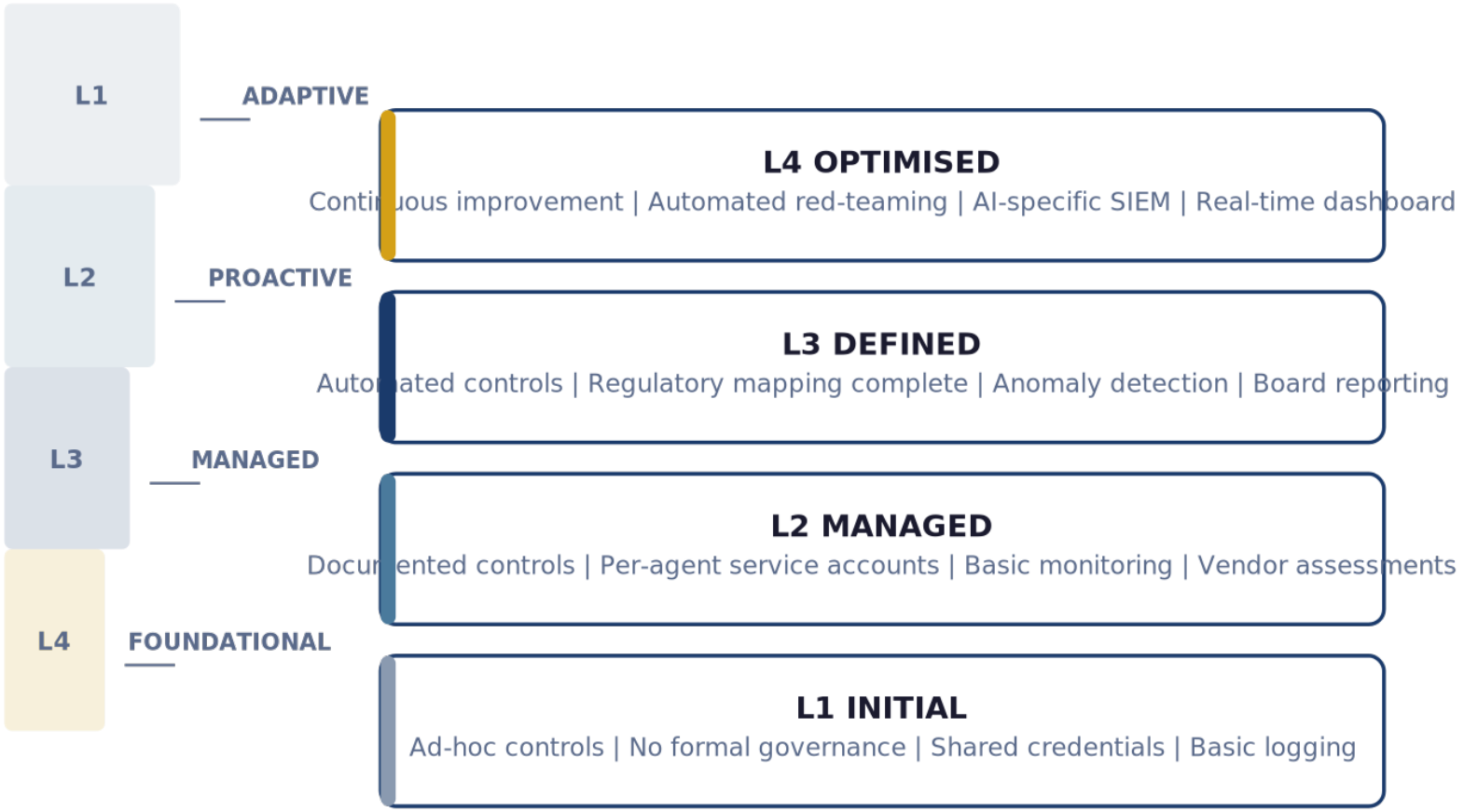
1. User request (authenticated, session-scoped)
2. Gateway: authN, WAF, intent filter, rate limit
3. Agent plans; tool invocation proposed
4. OPA: is agent authorised? scope? approval needed?
5. Tool gateway: schema validation, allow-list, audit
6. Output validated & sanitised before agent context
7. Response returned; full chain logged (MIR-01)




Fail-closed: any unreachable policy/tool/audit dependency blocks the action (EE-06, TP-03).

# Maturity: L1 to L4

Consistent with the ISM and Essential Eight maturity model




*L3 Defined: regulated entities and government agencies. L4 Optimised: critical infrastructure and national security.*

# Alignment with NBN Co's Regulatory Obligations

Seven pillars against SOCI Act, TSSR, the Privacy Act, ISM/E8, and the AU Guardrails

## SHIELD-AI alignment with NBN Co obligations

Seven pillars mapped to the regulatory set a Commonwealth-owned, SOCI-designated carrier operates under. Solid = direct control mapping. Gold = supporting contribution.

| | SOCI Act<br>CIRMP / 12h reporting | TSSR<br>Telecoms security | Privacy Act<br>APP 11 customer data | ISM / E8<br>Gov baseline | AU Guardrails<br>High-risk AI |
|---|---|---|---|---|---|
| **1 Model Security**<br>MS-01 .. MS-10 | ● | ● | ● | ● | ● |
| **2 Identity & Access**<br>IAM-01 .. IAM-09 | ● | ● | ● | ● | ● |
| **3 Data Security**<br>DS-01 .. DS-07 | ● | ● | ● | ● | ● |
| **4 Tool & Pipeline Security**<br>TP-01 .. TP-11 | ● | ● | ● | ● | ● |
| **5 Monitoring & IR**<br>MIR-01 .. MIR-06 | ● | ● | ● | ● | ● |
| **6 Governance & Risk**<br>GRM-01 .. GRM-06 | ● | ● | ● | ● | ● |
| **7 Execution Environment**<br>EE-01 .. EE-08 | ● | ● | ● | ● | ● |

SOCI Act: CIRMP risk management and 12-hour incident reporting for critical infrastructure (MIR-05). TSSR: carrier security obligations for network infrastructure (TP, MS). Priv

*Solid: direct control mapping. Gold: supporting contribution.*

# A Practical Starting Point

## The framework answers 'where do we start' in five steps

1. Posture assessment: score all seven pillars at L1-L4, find where network data already meets a model
2. Set the floor: make L2 the baseline for the first production system (identity, logging, sandbox, tool registry)
3. Pilot policy as code on one use case: pick the incident-report assistant or a network copilot, run it through the gateway, watch the logs
4. Board reporting cadence: GRM-06 dashboard from the first quarter, so the board sees posture, not anecdotes
5. Keep it current: monthly deep review and the live watchlist, so the control set tracks what attackers are actually doing

**None of this requires a platform rewrite; the reference implementation drops in beside what NBN Co already runs**

# Future Threats on the SHIELD-AI Watchlist

Six components under active monitoring; the watchlist is rebuilt monthly by the deep review

| Future threat | What is happening | Why it matters to SHIELD-AI |
|---|---|---|
| **IETF agent-to-agent (A2A) standardisation** | Protocol ratification talks may normalise multi-hop agent delegation | Could defeat the two-hop delegation bound (IAM-02/07); delegation-chain amplification |
| **Open Secure AI Alliance / NOOA** | NVIDIA and 36 partners, open-sourced guidance (July 2026) | Divergence risk if NOOA guidance contradicts a SHIELD-AI control; a mapping question for GRM-05 |
| **Time-based supply-chain defences** | TrapDoor (34 packages across npm, PyPI, Crates) showed token-age gates | The fresh-credential problem: agent publishers hold fresh tokens, so age-based gates miss agent-originated publication (DS-07) |
| **Edge and on-device agents** | Models like Gemma 4 12B run locally, outside the data centre | MS-09 needs a perception-channel extension (screen, OCR); on-device agents open a MIR-01 telemetry gap |
| **Inbound MCP exposure** | OX Security 'by design' flaw (200K servers, 150M downloads); Wiz research; Metasploit 6.5 now ships an MCP server | Strongest promotion candidate: extend TP-10 to standalone MCP servers |
| **Adversary-owned autonomous agents** | Unit 42 documented self-scanning campaigns; agent-as-a-service is spreading | Prevention cannot keep pace; rely on detection (MIR-02), automated response (MIR-04), and a tested kill switch (GRM-02) |

Each item carries a decision gate: when the gate fires, the item is promoted from watchlist to control.

Queued for the September deep review: inbound MCP exposure (extending TP-10) and A2A standardisation (extending IAM-07).

# Why SHIELD-AI for NBN Co

**Aligned: mapped to SOCI Act, TSSR, the Privacy Act, ISM/E8, and the AU Guardrails the carrier already operates under**

**Evidence driven: 62 incidents, a monthly deep review, a live watchlist; the controls track what attackers are actually doing**

**Deployable: a reference implementation with policy as code, ready to run beside existing platforms**

**Built for critical infrastructure: the 12-hour SOCI reporting clock is a design input, not an afterthought**

**Measurable: the L1-L4 maturity model gives the board a repeatable posture picture, quarter to quarter**

**Transparent: an open framework with no commercial lock-in, ready for independent evaluation**

# What This Means in Practice

**The question regulators will ask: how is AI secured under the SOCI Act and TSSR, and how do you evidence it across the entity?**

The answer framework: run the 67 controls as executable policy, and an audit becomes a test run

**The path from here:**

1. Posture assessment (weeks 1-4): current AI deployments scored L1-L4 against the 67 controls, with a prioritised gap list
2. Pilot (weeks 5-8): policy-as-code enforcement on one real use case, deployed as a sidecar, no platform rebuild
3. Rollout: extend to production workloads, wire to monitoring and audit, keep posture current through the ongoing incident watch

**The framework updates weekly against a live incident watch and monthly with a deep review; it does not go stale between engagements**

# Questions and Discussion

Which network-facing AI capability ships first, and where does network data meet a model today?

A useful next step: a seven-pillar posture assessment at L1-L4, then a policy-as-code pilot on that first use case.

SHIELD-AI v1.15 | 7 pillars | 67 controls | policy as code | October 1, 2026